

AgentGuard Product Brief

Governing AI-Agent Risk from Discovery to Safe Action

AgentGuard helps organizations understand AI-agent risk, create controlled remediations, and verify that a proposed change is safe before it moves forward—without putting an AI model in charge of security decisions or production changes.

AI agents are becoming more capable and more connected. They can operate under identities, call tools, access sensitive information, connect to APIs, and participate in workflows that affect real systems.

That creates a new security challenge.

Organizations want AI to help identify risk, explain what is wrong, and recommend how to fix it. But giving the same AI unrestricted authority to decide how serious a problem is, generate a change, approve it, and apply it creates a new source of risk.

The challenge is therefore not simply how to make AI more capable. It is **how to use AI while keeping important security decisions and actions controlled, reviewable, and accountable.**

AgentGuard is an AI-agent security reference product designed around that problem. It creates a governed path from discovering risk to taking action, while deliberately separating the responsibilities that should not belong to one system.

AI can explain and propose. Deterministic controls decide risk and constrain action. A human approves the exact change. AgentGuard independently verifies the result.

That principle shapes the product around three connected jobs: **DISCOVER** the risk, **REMEDiate** it through a controlled change, and **VALIDATE** the result before the change can move forward.

DISCOVER

Understand what an AI agent can do—and why it may be risky

Good governance starts with visibility.

An AI agent may have access to multiple tools, sensitive data, or privileged actions. Each capability may appear reasonable on its own, but the combination can create significant risk. A security team may know that an agent exists without having a clear picture of what it can actually do, why those capabilities matter, or which policies they may violate.

AgentGuard brings that information together through a **read-only connection using MCP**, a standard that allows AI systems to connect with external tools and data. Read-only is an important design choice: AgentGuard can gather the information needed to understand an agent without turning discovery itself into another way to change the environment.

Once the information is available, AgentGuard evaluates the agent against explicit security rules. **The result is deterministic**—the same rules applied to the same information produce the same security decision. The AI model does not decide the severity, change the score, or reinterpret the underlying policy. This keeps the risk decision predictable and testable.

AI is then used where it adds the most value: helping people understand the finding. AgentGuard retrieves approved policy evidence and uses AI to explain the issue in plain language. The explanation must stay grounded in the evidence it was given, so unsupported citations, invented quotations, or attempts to change the underlying security decision are rejected.

The division of responsibility is simple: **AgentGuard's rule-based controls determine the risk. AI helps people understand why.**

For security and platform teams, that means faster analysis and clearer explanations without turning the AI model into the security policy engine.

REMEDiate

Turn a finding into a controlled change

Understanding a security problem is useful only if the organization can safely do something about it.

This is also where AI creates a difficult tradeoff. A model may be able to suggest a plausible fix very quickly, but allowing it to freely generate and execute changes would turn the remediation system itself into a powerful privileged actor.

AgentGuard deliberately avoids that approach.

Instead of accepting arbitrary AI-generated changes, AgentGuard limits remediation to a small set of **predefined, allowlisted actions**. AI can help explain what should be done and recommend an appropriate response, but the actual change must fit within an action that AgentGuard already understands and knows how to check.

The next question is approval: how can the organization be sure that the reviewer approved the same change that will eventually be processed?

AgentGuard solves this by creating a **cryptographic fingerprint**, using SHA-256, of both the current source information and the proposed remediation. The reviewer's approval is tied to those exact fingerprints.

In plain English, the person is saying: **"I reviewed this specific change against this specific state, and this is what I approve of."**

If the underlying information changes after approval, or if someone changes the proposal, the fingerprints no longer match. The old approval becomes invalid and AgentGuard stops the workflow rather than allowing a previous decision to authorize something different.

This turns human approval into more than a checkbox. It creates a clear record of **what was reviewed, what was authorized, and whether that approval is still valid.**

But approval is still not the last step. AgentGuard also needs to check that the proposed remediation actually produces the expected result.

VALIDATE

Check that the proposed change works before it moves forward

A remediation may look correct when a reviewer approves it. The important question is what happens when that change is actually applied.

It could modify the wrong information, affect something that was never supposed to change, fail to reduce the original risk, or even make the environment less secure.

AgentGuard checks for those problems before **allowing the remediation to move forward**.

Instead of applying the approved change directly to the original environment, AgentGuard first applies it to a safe, isolated working copy. It then compares the result with the original state. AgentGuard checks that the intended item changed, unrelated information stayed intact, the resulting data remains valid, and the security risk did not increase. If those checks do not pass, the process stops.

The idea is straightforward: **A person approves the proposed change. AgentGuard then checks that the change actually produced the expected result.**

Only after a remediation is both **approved and successfully verified** can it move toward delivery.

Delivery remains controlled as well. AgentGuard defaults to a **dry run**, so the user can see what would happen before an external change is made. When live delivery is permitted, AgentGuard limits the action to an approved GitHub repository, approved file paths, and a dedicated branch. It can prepare the change as a **draft pull request** for review, but it cannot automatically merge into **main**, force-push changes, or execute arbitrary AI-generated commands.

The goal is not to replace enterprise change management with AI. It is to help teams move faster **without removing the review and control that consequential changes require**.

TESTING THE SAFEGUARDS

Prove that AgentGuard works — and that unsafe actions are stopped

Building security controls is not enough. We also need evidence that they work.

AgentGuard includes an automated testing and evaluation framework that checks both sides of the product: **valid workflows should succeed, and unsafe workflows should be blocked**.

The completed implementation passed **874 automated pytest tests** covering the product's major behaviors. In addition, AgentGuard includes a dedicated **10-case safety evaluation** that deliberately tries to break the controls. The tests attempt things such as reusing an outdated approval, targeting an unauthorized repository, skipping required workflow steps, or proposing a change that increases security risk. AgentGuard passes only when those unsafe actions are stopped, while a valid remediation is still allowed to proceed.

All 10 safety scenarios passed. The implementation also passed its security evaluation, secret scan, GitHub CI, and final release gate.

This matters because the goal is not simply to show that AgentGuard can complete a successful demo. The testing framework provides evidence that the product's safeguards continue to work when something unexpected or unsafe is attempted.

These results demonstrate disciplined testing of this reference implementation; they are not a claim of universal security or production certification.

A FOCUSED MVP WITH AN ENTERPRISE PATH

AgentGuard is intentionally built as a **synthetic reference product**. Using controlled data and environments makes the architecture, product decisions, and security safeguards easier to inspect, reproduce, and demonstrate without using production systems or customer data.

The current product focuses on proving the core governance model rather than trying to reproduce every capability of a commercial enterprise platform. It does not claim production-grade identity and role-based access control, separation of duties, multi-tenancy, high availability, broad enterprise integrations, or fully autonomous remediation.

Some deliberate MVP boundaries also remain. The reference workflow uses a simplified reviewer identity, for example, and durable audit components are implemented and tested while complete durable orchestration through the user interface remains future work.

For enterprise use, those foundations would need to expand. A production product would add enterprise identity and authorization, stronger multi-person approval workflows, authenticated remote MCP connections, production system connectors, tamper-evident audit records, broader remediation coverage, operational telemetry, and integration with existing security and change-management platforms.

The enterprise principle is clear: **As AI takes on more responsibility, organizations should be able to increase automation without weakening security governance, human accountability, or change control.**

AgentGuard is designed to demonstrate how those controls can remain intact as the workflow moves from understanding risk toward taking action.

THE TAKEAWAY

As AI agents gain access to more tools, data, and business processes, enterprises will need more than a way to find them—and more than a way to automate them.

They will need a trustworthy path from **seeing a risk to doing something about it.**

AgentGuard demonstrates that path.

With **DISCOVER**, security teams gain visibility into what an AI agent can do, evaluate that behavior against predictable security rules, and use AI to make the resulting risk easier to understand.

With **REMEDiate**, the organization turns the finding into a controlled proposal and makes sure that a person approves the exact change being considered.

With **VALIDATE**, AgentGuard checks the proposed result before it moves forward, making sure that the intended change occurred without introducing unexpected or higher risk.

Behind those three capabilities is a common principle: **Use AI where it helps people move faster, while keeping consequential security decisions and actions inside explicit, testable controls.**

The result is a governed journey from **risk to understanding, understanding to action, and action to evidence.**

MORE INFORMATION

Product Demo: https://youtu.be/HRcWwnvs_Ck

Public Technical Repository: <https://github.com/justintinlei/agentguard-v4>

LinkedIn: <https://www.linkedin.com/in/justinlei/>